

Konsekvensbedömning avseende dataskydd (DPIA) — utkast

Enligt GDPR artikel 35

Behandling: **CVmatchen** — AI-stödd CV- och jobbmatchningsplattform Personuppgiftsansvarig: **Helsingborgs stad, Arbetsmarknadsförvaltningen** Personuppgiftsbiträde: **PathfinderAI** (enskild firma; registrering av aktiebolag planeras inför skarpt avtal) Version: 1.0 — utkast 2026-06-18 Framtagen av: Oliver Pettersson (PathfinderAI) för granskning av kommunens dataskyddsombud (DSO/DPO)

Om detta utkast: En DPIA ska ägas och slutföras av den personuppgiftsansvarige (kommunen), i praktiken av dataskyddsombudet. Detta utkast är förberett av leverantören för att ge DSO ett underlag att bygga vidare på — inte en färdig bedömning. Fält markerade **[DSO fyller i]** kräver kommunens ställningstagande. Behandlingen får inte tas i drift förrän DPIA:n är slutförd och godkänd.

1. Behövs en DPIA?

En DPIA krävs när en behandling “sannolikt leder till en hög risk för fysiska personers rättigheter och friheter” (art. 35.1).

CVmatchen träffar flera av IMY:s och Art. 29-gruppens kriterier:

Kriterium	Träffas?	Motivering
Utvärdering/poängsättning (profilering)	Ja	AI rangordnar och motiverar jobbmatchningar
Automatiserat beslutsfattande med rättslig verkan	Nej*	AI är beslutsstöd — handläggaren fattar besluten
Systematisk övervakning	Delvis	Aktivitetsloggning av deltagares agerande
Känsliga uppgifter / art. 9-data	Ja (potentiellt)	Fritext i CV kan avslöja hälsa/ursprung
Sårbara registrerade	Ja	Arbetssökande i ekonomiskt beroendeförhållande till kommunen
Innovativ teknik	Ja	Generativ AI (LLM) för textproduktion
Storskalig behandling	Nej (pilot)	~10 deltagare i pilot; kan skala senare

*Aktivitetsloggen kan påverka handläggarens bedömning av aktivitetskravet, men leder aldrig ensam till ett automatiserat beslut. Se avsnitt 6.

Slutsats: DPIA krävs. Minst tre kriterier träffas (sårbar grupp, potentiellt känsliga uppgifter, innovativ AI-teknik).

2. Systematisk beskrivning av behandlingen

2.1 Ändamål

- Hjälpa arbetssökande skapa och förbättra CV
- Matcha deltagares profil mot lediga tjänster (Platsbanken)
- Erbjuda AI-baserad intervjuträning och kompetensutveckling
- Ge handläggare underlag för uppföljning av deltagare

2.2 Kategorier av registrerade

- Arbetssökande deltagare anvisade av Arbetsmarknadsförvaltningen
- Handläggare och administratörer

2.3 Kategorier av personuppgifter

Kategori	Exempel	Källa
Identitet	Namn	Deltagaren

Kontakt	E-post, telefon	Deltagaren
CV-innehåll	Utbildning, erfarenhet, kompetenser, referenser, ev. profilbild	Deltagaren
Aktivitetsdata	Inloggningar, sökta jobb, tilldelade uppgifter, modulprogress	Systemet
AI-konversationer	Intervjufrågor (text)	Deltagaren
Potentiellt art. 9	Hälsa/ursprung om deltagaren skriver in det i fritext	Deltagaren

2.4 Dataflöde

- 1. Deltagaren loggar in med e-post + engångskod (OTP).
- 2. Deltagaren matar in CV-data → lagras i Supabase (Frankfurt, EU).
- 3. Vid AI-funktion skickas relevant text till AWS Bedrock (Frankfurt, EU) → bearbetas → svar returneras → **lagras inte hos AI-leverantören, används inte för modellträning**.
- 4. Handläggaren ser deltagarens data via admin-panelen (endast egen kommun/enhet, RLS-skyddat).

2.5 Mottagare

- Kommunens handläggare (inom egen enhet)
- Underbiträden: Vercel (Stockholm), Supabase (Frankfurt), AWS Bedrock (Frankfurt), Resend (EU), Sentry (EU), Microsoft (inloggning, EU)

2.6 Lagringstid

- Under aktiv deltagarperiod + **[DSO fyller i — förslag: 24 mån efter senaste aktivitet]**
- Radering på begäran (art. 17) via “Radera mitt konto”
- Vid avtalsslut: radering/återlämning enligt PUB punkt 11

2.7 Geografisk placering

Samtliga behandlingar sker inom **EU/EES**. Ingen tredjelandsoverföring.

3. Bedömning av nödvändighet och proportionalitet

Fråga	Bedömning
Är ändamålet specifikt och legitimt?	Ja — kommunal arbetsmarknadsverksamhet
Är behandlingen nödvändig för ändamålet?	Ja — CV/matchning kräver personuppgifter
Kan ändamålet nås med mindre data?	Delvis — profilbild och känsliga fritext-uppgifter är frivilliga och bör minimeras
Laglig grund	Art. 6.1.e (allmänt intresse/myndighetsutövning)
Grund för art. 9-data	[DSO fyller i] — t.ex. 9.2.b (social trygghet) eller 9.2.g (viktigt allmänt intresse) med stöd i svensk lag
Ändamålsbegränsning	Data används endast för angivna ändamål
Uppgiftsminimering	Endast nödvändiga fält obligatoriska; övrigt frivilligt
Korrekthet	Deltagaren redigerar själv; AI-text godkänns av deltagaren
Transparens	Integritetspolicy + AI-samtycke i appen

4. Registrerades rättigheter — hur de tillgodoses

Rättighet	Hur
Information (art. 13-14)	Integritetspolicy vid registrering + AI-samtyckesruta
Tillgång (art. 15)	“Exportera mina data” i profilmeny

Rättelse (art. 16)	Deltagaren redigerar själv all sin data
Radering (art. 17)	“Radera mitt konto” — kaskaderar genom alla tabeller
Begränsning (art. 18)	Handläggare kan pausa konto
Dataportabilitet (art. 20)	Export i öppet, maskinläsbart format
Invändning (art. 21)	Kontakt till kommunen som PUA
Återkalla samtycke (art. 7.3)	AI-samtycke kan när som helst dras tillbaka i appen

5. Riskanalys

Skala: Sannolikhet (Låg/Medel/Hög) × Konsekvens (Låg/Medel/Hög)

R1 — Obehörig åtkomst till personuppgifter

- **Sannolikhet: Låg | Konsekvens: Hög | Risk: Medel**
- Hot: Angripare kommer åt CV-data, aktivitetslogg
- Skydd: RLS, multi-tenant-isolation, HMAC-tokens, TLS 1.3, kryptering at rest, avvisade försök loggas
- **Restrisk: Låg-Medel**

R2 — Cross-tenant-läcka (handläggare ser fel kommuns deltagare)

- **Sannolikhet: Låg | Konsekvens: Hög | Risk: Medel**
- Skydd: serverside `verifyAdmin` med deny-by-default, kommun/enhet-check på varje admin-anrop (fixad i commit 709302e)
- **Restrisk: Låg**

R3 — Känsliga uppgifter (art. 9) i fritext

- **Sannolikhet: Medel | Konsekvens: Hög | Risk: Hög**
- Hot: Deltagaren skriver in hälsa/ursprung i CV-fritext utan att inse det behandlas av AI
- Skydd: AI-samtycke krävs; **[ÅTGÄRD: lägg till varningstext vid fritextfält om att inte skriva känsliga uppgifter]**
- **Restrisk: Medel** — kräver åtgärd

R4 — AI genererar felaktig/missvisande text

- **Sannolikhet: Medel | Konsekvens: Medel | Risk: Medel**
- Skydd: människa-i-loopen — deltagaren granskar och godkänner all AI-text innan användning; inget registreras automatiskt
- **Restrisk: Låg**

R5 — AI-data lämnar EU

- **Sannolikhet: Låg | Konsekvens: Hög | Risk: Låg-Medel**
- Skydd: AWS Bedrock EU (eu-central-1), `eu.anthropic.*`-modell-ID:n, ingen lagring/träning hos leverantör (aktivt sedan 2026-06-18)
- **Restrisk: Låg**

R6 — Aktivitetslogg påverkar försörjningsstöd felaktigt

- **Sannolikhet: Låg | Konsekvens: Hög | Risk: Medel**
- Hot: Handläggare tolkar loggen som facit, drar in stöd på felaktig grund
- Skydd: loggen är underlag, inte beslut; bedömningen görs av handläggare med helhetssyn; **[ÅTGÄRD: dokumentera för handläggare att loggen är ett av flera underlag]**
- **Restrisk: Låg-Medel**

R7 — Leverantörsberoende (liten leverantör upphör)

- **Sannolikhet: Medel | Konsekvens: Medel | Risk: Medel**
- Skydd: källkodsdeponering (escrow), dataportabilitet, SLA, kontinuitetsplan i avtalet
- **Restrisk: Låg-Medel**

R8 — Nyckel-/credential-läcka

- **Sannolikhet: Låg | Konsekvens: Hög | Risk: Medel**
- Skydd: krypterade env-variabler, nyckelrotation, service-nycklar aldrig i klient; **[ÅTGÄRD: rotera flaggade nycklar + inför 90-dagars rotationsrutin]**
- **Restrisk: Låg efter åtgärd**

6. Automatiserat beslutsfattande (art. 22)

CVmatchen genomför **inget** automatiserat beslutsfattande med rättslig verkan eller motsvarande betydande påverkan enligt art. 22.

- AI **föreslår** — deltagaren och handläggaren **beslutar**.
- Matchningsmotiveringar och profiltexter är förslag som människan godkänner.
- Aktivitetsloggen är ett underlag bland flera i handläggarens helhetsbedömning.

Detta är en central rättssäkerhetsgaranti för en sårbar målgrupp och ska säkerställas i handläggarutbildning och rutinbeskrivning.

7. Åtgärdsplan — innan driftsättning med persondata

#	Åtgärd	Ansvarig	Status
1	Varningstext vid CV-fritextfält (skriv ej känsliga uppgifter)	PathfinderAI	✓ (2026-06-18)
2	Handläggarrutin: aktivitetslogg = underlag, ej beslut	Kommunen	⌘
3	Rotera flaggade API-nycklar + 90-dagarsrutin	PathfinderAI	⌘
4	PUB-avtal undertecknat	Båda	⌘
5	Fastställ laglig grund för art. 9-data	DSO	⌘
6	Fastställ lagringstid	DSO	⌘
7	Extern WCAG-granskning	PathfinderAI	⌘ (tidigt i pilot)
8	Bekräfta AI-samtyckesflöde i drift	PathfinderAI	✓ (live)
9	Bekräfta Bedrock-EU aktivt	PathfinderAI	✓ (2026-06-18)
10	DPIA slutförd och godkänd	DSO	⌘

8. Samråd

- **Dataskyddsombud (DSO):** ska granska och godkänna denna DPIA innan driftsättning. **[DSO:s bedömning och signatur]**
- **Förhandssamråd med IMY (art. 36):** krävs endast om DPIA:n visar hög restrisk som inte kan mildras. Bedömning: **[DSO fyller i]** — troligen ej nödvändigt givet skyddsåtgärderna, men DSO avgör.

9. Slutsats och godkännande

Restriskerna bedöms som **hanterbara** förutsatt att åtgärderna i avsnitt 7 genomförs. De högsta riskerna (R3 känsliga fritext-uppgifter) mildras genom varningstext, AI-samtycke och människa-i-loopen.

Behandlingen får inte tas i drift med skarpa personuppgifter förrän: - åtgärd 1-6 i avsnitt 7 är slutförda, och - DSO har godkänt denna DPIA.

Godkännande av dataskyddsombud (Helsingborgs stad):

Namn: _____ Datum: _____ Signatur: _____

Bedömning: ☐ Godkänd ☐ Godkänd med villkor ☐ Kräver förhandssamråd IMY

Ev. villkor: _____

Underlag: teknisk specifikation (2026-06-17), PUB-utkast (2026-06-17), säkerhetsgranskning (2026-05-15), Bedrock-EU-migration (aktiv 2026-06-18).